

Yuzu Immigration

Security, privacy, and operations policy pack

Zoom Marketplace additional documents — 16 August 2026

Operator: Yuzu Solutions. Product: Yuzu Immigration (practice-management CRM for Canadian immigration consultants). Production: <https://my-consultant.vercel.app>. Privacy contact: privacy@yuzu.solutions.

SOC 2: Yuzu Solutions does **not** currently hold a SOC 2 report for Yuzu Immigration. Do not treat this pack as a Yuzu SOC 2 certification. Primary data host **Supabase** and application host **Vercel** each publish SOC 2 Type 2 reports for their platforms. Those reports cover subprocessors, not Yuzu Solutions as the app operator.

Contents

- A. Information security policy
- B. Vulnerability management policy
- C. Data retention and protection policy
- D. Incident management and response policy
- E. Infrastructure and dependency management policy
- F. Privacy policy (summary + public URL)
- G. Certifications and subprocessors

These documents describe how Yuzu Solutions actually operates Yuzu Immigration, including the Zoom Meeting integration (OAuth, meeting create/update/delete, encrypted token storage). They are written for Zoom’s confidential security review. They are not legal advice and are not a PIPEDA or ISO certification.

A. Information security policy

Purpose. Protect firm, staff, client, booking-guest, and Zoom-connected account data against unauthorized access, alteration, and disclosure, in proportion to the sensitivity of Canadian immigration files.

Scope

All production systems for Yuzu Immigration: Next.js application on Vercel, Supabase (Auth, Postgres, Storage) in AWS Canada Central, and third-party integrations a consultant may connect (Google, Microsoft, Zoom, Resend).

Controls

- **Secrets:** Zoom, Google, Microsoft, Supabase service-role, and encryption keys are stored only in Vercel environment variables and local `.env.local` (gitignored). Never in `NEXT_PUBLIC_*` variables, client bundles, or source control.
- **Authentication:** Staff use Supabase Auth (email/password or Google). Client portal passwords are stored in a private schema and verified only on the server. Public booking and share links use unguessable tokens.
- **Authorization:** Postgres row-level security isolates firms. Assistants see only shared projects. Service-role database access is limited to audited server paths and RPCs.
- **Encryption in transit:** TLS 1.2+ for the application, database connections, and Zoom/Google/Microsoft APIs.
- **Encryption at rest:** Platform encryption for database and storage. Application-level AES-256-GCM for uploaded documents, many client fields, and Zoom/Google/Microsoft OAuth tokens, using a per-firm data key.
- **Zoom least privilege:** Confidential OAuth client. Scopes limited to `user:read:user` and `meeting:write:delete`. No Zoom SDK, recordings, chat, phone, or webhooks. Guest email is not sent to Zoom as a registrant.
- **Logging:** Security audit events for sensitive CRM actions. Zoom tokens are not written to application logs. Minimize PII in logs.
- **Access to production:** GitHub, Vercel, and Supabase admin access is limited to Yuzu Solutions operators who need it.

Coding standards (checked into the engineering repo) require Zod validation of external input, no secrets in git, and RLS on user-facing tables. Failed TypeScript, ESLint, or production builds are not released.

B. Vulnerability management policy

Identify, triage, and remediate vulnerabilities in Yuzu Immigration source code and production dependencies before they can be exploited, with extra scrutiny on code that handles OAuth tokens or Zoom APIs.

- **Static testing (SAST):** Semgrep with OWASP Top 10, TypeScript, and Next.js rules on src/. Latest scan 16 August 2026: 380 files, 0 findings after triage. An earlier GCM authTagLength finding was fixed by passing { authTagLength: 16 } on AES-256-GCM cipher APIs.
- **Component analysis (OSCA):** npm audit against the lockfile before production releases. Latest production-omit audit: 0 vulnerabilities.
- **Complementary gates:** TypeScript strict compile, ESLint (eslint-config-next), Next.js production build.
- **Schema review:** Versioned Supabase SQL migrations. Security Advisor reviewed after schema changes. private.zoom_secrets has no client RLS policies (service-role RPCs only).
- **Severity and SLA:** Critical/high issues that expose Zoom tokens, client PII, or tenant isolation are treated as incidents (section D) and patched before further Zoom-related releases. Medium/low issues are scheduled into the next production deploy.
- **Disclosure:** Researchers or firms may report issues to privacy@yuzu.solutions. We do not run a public bug bounty.
- **Out of current pipeline:** Automated DAST (ZAP/Burp CI) and third-party penetration testing are not yet scheduled. Zoom's Marketplace review includes OWASP testing of Zoom-facing surfaces.

C. Data retention and protection policy

Protection

- Primary application data (database, Auth, Storage) is hosted in Canada (Supabase / AWS ca-central-1).
- Uploaded client documents and many identity/contact fields are encrypted with AES-256-GCM using a per-firm data encryption key wrapped by DOCUMENT_ENCRYPTION_KEY.
- Zoom refresh and access tokens are encrypted the same way and stored in private.zoom_secrets. Staff Zoom email and user id are stored on zoom_connections. Meeting id and join URL are stored on booking_appointments.
- Data sent to Zoom for a meeting: topic (truncated to 200 characters), start_time, duration. Not sent: guest email, phone, address, immigration files, or IRCC form contents.

Retention

- Active firm workspaces retain client and project records while the workspace is active.
- When a file is closed, the product sets retain_until to six years after closure (College of Immigration and Citizenship Consultants closed-file practice).
- Staff may delete a person or project (erasing application PII, documents, questionnaire answers, share links, portal access, and attempting to delete the matching calendar event and Zoom/Teams meeting).
- Disconnecting Zoom deletes that staff member's Zoom OAuth tokens from Yuzu Immigration.
- After retain_until, a firm administrator may destroy a closed file. A placeholder project row and an encrypted destruction-register entry remain for the firm's professional record. Related security audit rows are retained with IP, user-agent, and event metadata removed.
- Hashed booking rate-limit events are deleted after about 14 days.
- Emails already sent, copies of meetings held by Zoom/Google/Microsoft, and database backups can outlive an application delete until those copies expire.

D. Incident management and response policy

An incident is unauthorized access, disclosure, or loss of personal information or Zoom OAuth tokens; a suspected compromise of production credentials; or a vulnerability being actively exploited.

Roles

Privacy and security contact: privacy@yuzu.solutions. Engineering owner: Yuzu Solutions development team. Firms remain responsible for notifying their own clients when their files or bookings are affected.

Response steps

- **Detect:** Operator alerts, customer reports, unusual Zoom/Google/Microsoft API errors, failed auth spikes, or Security Advisor findings.
- **Contain:** Revoke or rotate exposed secrets (ZOOM_CLIENT_SECRET, DOCUMENT_ENCRYPTION_KEY, service-role key). Disconnect or delete stored OAuth tokens. Disable the affected integration if needed. Rotate Zoom Marketplace credentials if the confidential client secret leaked.
- **Assess:** Determine what data was involved (Zoom tokens vs client PII vs tenant isolation). Under PIPEDA, assess whether there is a real risk of significant harm.
- **Notify:** Where required, notify affected firms and individuals and report to the Office of the Privacy Commissioner of Canada. Give firms the facts they need for their own notices. Notify Zoom if Zoom user tokens or the Zoom app secret were compromised.
- **Eradicate and recover:** Patch, redeploy, confirm tokens were deleted or re-encrypted, and restore service from known-good configuration.
- **Post-incident:** Record the event, root cause, and follow-up actions. Update this pack and the public privacy policy if practices change.

In-product audit logs (Settings → Security) support investigation of downloads, uploads, share links, and deletions. They are not a SIEM. Near-misses should still be recorded internally.

E. Infrastructure and dependency management policy

- **Source control:** Private GitHub repository. Production deploys from the main branch to Vercel over HTTPS.
- **Runtime:** Next.js 16 App Router, React 19, TypeScript, Node.js on Vercel Fluid Compute. No Zoom Meeting SDK.
- **Data plane:** Supabase project in Canada Central (Postgres + Auth + Storage). Drizzle ORM. RLS enabled on user-facing tables.
- **Dependencies:** npm with a committed lockfile. Production dependencies are audited (npm audit). Upgrades that fix high-severity issues are prioritized. Unused or abandoned packages are not added without review.
- **Zoom SDK / libraries:** Zoom is called with native HTTPS fetch to oauth.zoom.us and api.zoom.us. No zoomus SDK in the application.
- **Environments:** Local development uses .env.local. Production secrets are set in Vercel. Placeholder values such as the string ZOOM_CLIENT_ID are rejected at runtime.
- **Patching hosts:** Vercel and Supabase apply platform patches. Yuzu patches application dependencies and Next.js via planned upgrades and production builds.
- **Subprocessors:** listed in section G. New subprocessors that receive personal information require a privacy-policy update and firm notice when practical.

F. Privacy policy

Public policy (authoritative): <https://my-consultant.vercel.app/en/privacy>
French: [/fr/privacy](#) Spanish: [/es/privacy](#)
Last updated: 16 August 2026. Contact: privacy@yuzu.solutions

Yuzu Immigration is operated by Yuzu Solutions as a service provider to consulting firms. The firm is generally responsible for the client file. Yuzu Solutions is responsible for staff account data used to run the service. The public policy is written to support PIPEDA accountability. It is not a certification.

Zoom-related processing (from the public policy)

- A consultant may connect Zoom under Settings → Calendar → Meetings. This is independent of Google Calendar or Outlook.
- We store encrypted OAuth tokens, the connected Zoom email and user id, and (for bookings) the Zoom meeting id and join URL.
- We create/update/delete meetings with topic, start time, and duration. We do not send the guest's email to Zoom, do not access recordings/chat/phone, and do not use Zoom data for advertising.
- Disconnecting Zoom deletes that staff member's Zoom tokens from Yuzu Immigration. Deleting a booking attempts to delete the matching Zoom meeting.
- Zoom processes meeting metadata outside Canada. Firms remain responsible for Law 25 transfer assessments where those apply.

Consent: staff accept the Privacy Policy and Terms when creating an account. Public booking and client share links require both checkboxes before data is submitted. We do not sell personal information.

G. Certifications and subprocessors

Yuzu Solutions certifications

Yuzu Solutions does not currently hold SOC 2, ISO/IEC 27001, or similar third-party certifications for Yuzu Immigration. This pack plus the live privacy policy, SSDLC document, architecture diagram, and Semgrep/npm-audit evidence are the security artifacts available for this Zoom review.

Subprocessor certifications (not Yuzu's own)

Provider	Role	Notes
Supabase	Database, Auth, Storage (Canada)	SOC 2 Type 2 available to customers from the Supabase dashboard. DPA available at supabase.com/legal/dpa .
Vercel	Application hosting, analytics	SOC 2 Type 2 / platform security reports published by Vercel. TLS termination for my-consultant.vercel.app .
Resend	Transactional email (when configured)	May include a Zoom join URL in booking mail. Used only if the firm enables email.
Google / Microsoft	Optional calendar or meeting tools	Connected per staff member. Independent of Zoom OAuth.
Zoom	Optional meeting join links	User-managed OAuth. Confidential client. Meeting APIs only.

A firm data-processing addendum template exists for legal review (not an executed certificate). Public Terms: <https://my-consultant.vercel.app/en/terms>

Attestation. This pack is the current Yuzu Solutions policy set for Yuzu Immigration as of 16 August 2026.
Questions: privacy@yuzu.solutions.